

Information Security Policy

Organization: Cybersecurity Clinic Club

Standard: ISO/IEC 27001:2022

Version: 3.1 (Post-External Audit Remediation)

Effective Date: 12/18/25

Approved By: Syed – Security Manager

Version History:

Version	Date	Description	Approved By
1.0	11/29/25	Initial ISMS policy release	Security Manager
2.1	12/12/25	Post-Internal Audit Remediation	Security Manager
3.1	12/18/25	Post-External audit remediation	Security Manager

6. Risk Management

6.1 Risk-Based Approach

The Clinic adopts a risk-based approach grounded in the **Confidentiality, Integrity, and Availability (CIA)** model to identify and manage information security risks.

6.1.2 Information Security Risk Assessment

(ISO/IEC 27001:2022 Clause 6.1.2)

The Cybersecurity Clinic performs information security risk assessments using a defined and

repeatable methodology based on the CIA model.

Risk Identification

Risks are identified related to:

- Unauthorized access
- Cloud misconfiguration
- Privileged access misuse
- Loss or alteration of information
- Unavailability of cloud resources

Each risk is mapped to affected assets and CIA impact areas.

Risk Analysis Criteria

Likelihood Levels

Level	Description	Example
Low	Unlikely to occur	IAM role is restricted, MFA is enforced, no prior audit findings or incidents
Medium	Could occur occasionally	Temporary cloud misconfiguration during lab setup or testing activities
High	Likely without controls	Publicly exposed service or privileged account without MFA

Impact Levels (CIA)

Level	Description	Example
Low	Minimal disruption	Accidental deletion of internal documentation with backups available
Medium	Noticeable disruption or limited exposure	AWS S3 bucket storing non-sensitive lab results
High	Significant disruption or exposure	Compromise of an AWS management account leading to data exposure or service shutdown

Risk Evaluation Matrix

Likelihood \ Impact	Low	Medium	High
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	High

6.1.3 Information Security Risk Treatment

(ISO/IEC 27001:2022 Clause 6.1.3)

The Clinic handles identified risks by selecting appropriate risk treatment options and implementing controls to reduce risk to acceptable levels. Risk treatment ensures that information assets are protected while supporting operational objectives.

Risk Treatment Options

- **Mitigate** – Implement technical, administrative, or procedural controls to reduce the likelihood and/or impact of the identified risk to an acceptable level.
- **Accept (with justification)** – Acknowledge the risk without additional controls when the risk level is low and within the organization's defined risk tolerance, with documented approval.
- **Avoid** – Eliminate the risk entirely by discontinuing or changing the activity that gives rise to the risk.
- **Transfer (where applicable)** – Shift the financial or operational impact of the risk to a third party, such as through insurance, contractual agreements, or managed service providers.

Concrete Example

Asset: AWS member account

Threat: Unauthorized administrative access

Likelihood: Medium

Impact: High (confidentiality and integrity)

Risk Level: High

Treatment: IAM role-based access, MFA enforcement, CloudTrail logging, audit review

Residual Risk: Medium

Asset: AWS S3 bucket storing non-sensitive lab results

Threat: Accidental overwriting or deletion of files by students

Likelihood: Medium

Impact: Medium (availability and integrity)

Risk Level: Medium

Treatment: Enable S3 versioning, Restrict write/delete permissions to authorized roles, Implement periodic backup and recovery tests.

Residual Risk: Low

Asset: Internal ISMS documentation stored in Amazon S3

Threat: Accidental deletion of documentation

Likelihood: Low

Impact: Low (availability)

Risk Level: Low

Treatment: Accept with justification; S3 versioning enabled and access restricted

Residual Risk: Low

Risk assessments are documented in a Risk Register and reviewed during audits and management reviews.

6.3 Planning of Changes

(ISO/IEC 27001:2022 Clause 6.3)

The Cybersecurity Clinic recognizes that planned and controlled changes to its Information Security Management System (ISMS), cloud resources, and operational procedures are essential to maintain security, availability, and compliance.

Change Management Process

1. **Change Request Submission**
 - Any member proposing a change must submit a **Change Request Form** detailing description of the change, assets affected, rationale for the change, expected impact on security, availability, and operations
2. **Impact Assessment**
 - The **Security Manager** evaluates the proposed change against the **CIA model** (Confidentiality, Integrity, Availability)
 - Potential risks are identified, and mitigation measures are recommended
3. **Approval**
 - Changes must be **formally approved** by the Security Manager before implementation
 - High-impact changes require additional review by Clinic leadership or audit team
4. **Implementation**
 - Changes are implemented according to the approved plan
 - All actions are **documented in a Change Log in Amazon S3 bucket**, including date, personnel responsible, and details of implementation
5. **Testing and Validation**
 - Post-implementation testing ensures that changes **do not compromise security, compliance, or operational functionality**
6. **Monitoring and Review**
 - The Audit Lead reviews change records and validates that changes were implemented correctly and safely
 - Lessons learned are captured for **continuous improvement**
7. **Record Retention**
 - All change requests, impact assessments, approvals, testing results, and evidence are retained as **ISMS records**

7. Participation, Terms, and Responsibilities

Participation in the Clinic is conditional on adherence to information security requirements. All participants must:

- Follow acceptable use expectations
- Maintain confidentiality of Clinic and client information
- Use systems only as authorized
- Report suspected security incidents

Violations may result in restricted access, removal from Clinic activities, or academic escalation.

7.1. Competence and Training (Clause 7.2)

The success of this framework relies on the competence of the three key roles.

Syed: Must be trained on the strategic importance of the ISMS and Risk Management. •

Safwan: Required to hold or work towards AWS Security certifications (e.g., AWS Certified Security - Specialty) to ensure technical competence in implementing controls. • **Bilal:**

Required to understand ISO 19011 (Guidelines for auditing management systems) to conduct effective internal audits.

Name	Role	Training Topic	Link	Date	Method	Status
Syed	Security Manager	ISMS & Risk Management	https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html	2025-02...	Online c... ▾	Compl... ▾
Safwan	Documentation Lead	AWS Security Basics	https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html	2025-02...	Online c... ▾	In Pro... ▾

Bilal	Audit Lead	ISO 19011 Audit Guidelines	https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html	2025-02...	Online c... ▾	Compl... ▾
-------	------------	----------------------------------	---	------------	---------------	------------

<https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>

Annual Training Plan:

- **Q1:** Review of updated Policies (CIA, NC Framework).
- **Q3:** Tabletop Exercise (Incident Response Simulation).
- **Continuous:** Phishing simulation Awareness Training.
<https://www.microsoft.com/en-us/security/business/threat-protection/attack-simulation-training>

7.2 Screening and Employment Checks

All personnel engaged by the Clinic, including employees and contractors, must undergo appropriate screening prior to being granted access to information assets. Screening ensures personnel are reliable and suitable for roles with access to sensitive information.

Screening Activities May Include:

- Verification of identity and credentials
- Reference checks
- Criminal background checks (where applicable)
- Review of prior employment history or relevant experience

Responsibility:

- The Security Manager oversees the screening process and retains records as part of ISMS documentation.

7.3 Disciplinary Process

The Clinic maintains a structured process for addressing violations of information security requirements. Disciplinary actions may include:

- Access restriction
- Removal from Clinic activities or projects
- Employment or academic escalation

7.4 Responsibilities After Termination or Change of Employment

Personnel leaving or changing roles must:

- Return Clinic-owned assets
- Revoke access to all systems and cloud resources
- Ensure organizational data is preserved and protected

7.5 Non-Disclosure Agreements (NDAs)

All personnel with access to sensitive information must sign NDAs to protect confidentiality and reduce organizational risk.

7.6 Remote Working

Remote work is permitted; personnel must follow security measures for endpoint devices, including:

- Antivirus or built-in endpoint protection enabled
- Use of VPN for secure connectivity
- Awareness of malware risks and phishing attempts

- Compliance with data protection policies

AI Usage Disclaimer

The Cybersecurity Clinic may use AI tools for educational and operational support. AI-generated outputs are reviewed by humans before use and must not include confidential, client, or personal data. The Clinic remains responsible for all decisions and outcomes resulting from AI-assisted work.